

Step 18 — Automated API tests (manual test guide)

Goal: Confirm Vitest API tests run against a dedicated `fms_test` database (or embedded Postgres if local Postgres is down) and cover auth/tenant isolation, dynamic fields, expense CRUD, and income + net balance.

Maps to: Phase 1–6 testing (FMS-10, FMS-19, FMS-29, FMS-52)

Depends on: Steps 01–17 (existing APIs; no new HTTP routes)

Artifacts:

- Markdown: `docs/manual-test-guides/step-18-automated-tests.md`
- PDF: `docs/manual-test-guides/step-18-automated-tests.pdf`
- Server: `cd server && npm test`
- No new HTTP APIs (Postman collection unchanged)

Prerequisites

- ☐ Steps 01–17 already implemented
- ☐ `server/.env.local` exists with `DATABASE_URL` and `JWT_SECRET` (min 32 chars)
- ☐ PostgreSQL running **or** allow the test harness to start embedded Postgres (used automatically if `localhost:5432` is down)

Setup commands

From `finance-management/server` :

```
npm install
npx prisma generate
npm test
```

Watch mode (optional):

```
npm run test:watch
```

Tests rewrite `DATABASE_URL` to database `fms_test` . They never truncate `fms_dev` . If local Postgres is unreachable, the harness starts a temporary embedded Postgres on a high port.

Checklist

A. Harness

#	Test	Expected	Pass?
A1	<code>cd server && npm test</code>	Exit code 0; 19 tests pass (4 files)	[]
A2	Console / Prisma log	Datasource is database <code>fms_test</code> (not <code>fms_dev</code>)	[]
A3	After tests, open the app against <code>fms_dev</code>	Dev data is unchanged	[]

B. FMS-10 — Auth, tenant isolation, permission denial

Covered by `server/test/auth-tenant.test.ts` .

#	Test	Expected	Pass?
B1	Register + login + <code>/auth/me</code>	201 / 200; httpOnly session cookie	[]
B2	Bad password / no cookie	401 <code>INVALID_CREDENTIALS</code> / <code>UNAUTHORIZED</code>	[]
B3	Duplicate email / short password	409 <code>EMAIL_TAKEN</code> / 400 <code>VALIDATION_ERROR</code>	[]
B4	Deactivated user login	403 <code>USER_INACTIVE</code>	[]
B5	Company B cannot read company A expenses	404 <code>EXPENSE_NOT_FOUND</code> ; empty list	[]
B6	Guest write / normal-user write	401 <code>UNAUTHORIZED</code> / 403 <code>FORBIDDEN</code> ; normal user can still GET list	[]
B7	Super Admin finance routes / company admin tenant admin APIs	403 <code>TENANT_REQUIRED</code> / 403 <code>FORBIDDEN</code>	[]

C. FMS-19 — Dynamic fields

Covered by `server/test/fields.test.ts` .

#	Test	Expected	Pass?
C1	Create a required TEXT field and use it on an expense	Field 201; expense without value 400 <code>FIELD_REQUIRED</code> ; with value 201	[]
C2	Company B cannot see company A field definitions	Empty list; GET by id 404 <code>FIELD_NOT_FOUND</code>	[]
C3	Invalid key / dropdown without choices	400 <code>VALIDATION_ERROR</code>	[]

D. FMS-29 — Expense CRUD

Covered by `server/test/expenses.test.ts` .

#	Test	Expected	Pass?
D1	Create / read / update / list	201 then 200; amount stored as decimal string	[]
D2	Soft delete	GET/list/PATCH after delete → 404 <code>EXPENSE_NOT_FOUND</code>	[]
D3	Cross-tenant GET/PATCH/DELETE	404; original tenant can still GET	[]
D4	Amount 0 / negative / bad date / missing date	400 <code>VALIDATION_ERROR</code>	[]

E. FMS-52 — Income + net balance

Covered by `server/test/income.test.ts`.

#	Test	Expected	Pass?
E1	Income create / read / update / list	201 then 200; type is INCOME	[]
E2	Soft delete	404 INCOME_NOT_FOUND; list empty	[]
E3	Cross-tenant GET	404 INCOME_NOT_FOUND	[]
E4	Dashboard custom range: income 100, expense 40	kpis.netBalance is "60.00"	[]
E5	Soft-deleted expense/income excluded from KPIs	Net balance updates after each delete	[]

Negative / safety notes

- Tests **refuse** to run if `DATABASE_URL` does not point at `fms_test` (`assertTestDatabaseUrl`).
- `server/.env.test` is generated by the harness and gitignored.
- First run with embedded Postgres may take ~30–60s while the cluster initialises.

When all required items pass: mark Notion tasks **FMS-10, FMS-19, FMS-29, FMS-52** Done. Remaining product item: secure storage hardening (**FMS-23**, Step 19).